

A09

LOGGING & ALERTING FAILURES

OWASP 2025: 'Monitoring' → 'Alerting' — logs without alerts are silent failures

Two equal obligations: log enough to detect & respond · never log what creates a GDPR liability

Every Security Log Event Must Contain These Six Fields

Field	Example Value	Why It Matters	What Is Missing Without It
<code>event</code>	"LOGIN_FAILURE"	Identifies the type of security-relevant action. Enables SIEM rules and alerting thresholds.	Without event type, all log entries look identical. No SIEM rule can distinguish a login failure from a page view.
<code>timestamp</code>	"2026-03-20T10:23:41.847Z"	UTC, millisecond precision. Required for incident timeline reconstruction and UK GDPR Article 33 72-hour notification.	Without precise timestamps, attack timelines cannot be reconstructed. Audit logs become inadmissible for regulatory purposes.
<code>user_id</code>	"usr_4829" (not username)	Immutable identifier. A username can be changed; a <code>user_id</code> cannot. Links every event to one account regardless of renames.	Without <code>user_id</code> , an attacker who renames their account can sever the audit trail. Username alone is mutable and unreliable.
<code>source_ip</code>	"203.0.113.47"	Enables geolocation, threat intelligence lookups, IP-based rate limiting, and attribution to a network source.	Without <code>source_ip</code> , distributed attacks (credential stuffing from a botnet) are invisible. No basis for IP-based blocking or alerting.
<code>success</code>	false	Explicitly records the outcome. HTTP status codes alone are insufficient — a 302 redirect can indicate both success and bypass.	Without explicit outcome, failed and successful logins look identical in HTTP access logs. Cannot distinguish SQLi bypass from legitimate login.
<code>correlation_id</code>	"req_8f2a9c"	Ties together: the HTTP request, the security log entry, any A10 exception log, and the response sent to the client.	Without <code>correlation_id</code> , a support engineer cannot match an error report ('I got a reference: req_8f2a9c') to a server-side exception log.

What to Never Log — UK GDPR / DPA 2018 & Security Requirements

Never Log	Why	Legal/Security Basis	Log This Instead
Passwords (any form)	A log containing hashed passwords is a credential database. Stolen logs give attackers offline cracking material.	No security benefit — the hash is not needed for audit purposes. Creates GDPR Article 5(1)(e) storage limitation violation.	event: LOGIN_FAILURE, user_id, source_ip, success: false. Never the credential submitted.
Full session tokens / JWTs	A full token is equivalent to a username+password pair. Stolen from logs = session hijacking toolkit.	UK GDPR Article 25: data minimisation by design. A full token provides no audit value beyond a correlation_id.	First 8 characters of token only as a correlation reference. Or: a token_id from a server-side session table.
Full payment card numbers (PANs)	PCI-DSS prohibits storage of full PANs beyond authorisation. Logs are rarely PCI-scoped storage.	PCI-DSS Requirement 3.3 prohibits storing full PAN after authorisation. UK GDPR: unnecessary sensitive data retention.	card_last4 (last 4 digits only) and transaction_id. Never the full 16-digit number.
Full stack traces in client-facing log channels	Stack traces disclose: framework version, internal file paths, class/function names, DB schema. All useful for targeted attacks.	A10 Mishandling of Exceptional Conditions (Module 10): stack traces to clients are an information disclosure failure.	correlation_id only in the client-facing event. Full trace written to a separate, access-controlled server-side log only.
Personal identifiers beyond what is needed	Name, email, date of birth, home address — unless directly relevant	UK GDPR Article 5(1)(b): purpose limitation. Article 5(1)(c): data	user_id (internal, non-personal). If email is the only identifier: hash it with

Module 11 — A09 Logging & Alerting Failures · Quick Reference Card

BBC Academy / JBI Training

	to the security event being recorded.	minimisation. Log what is needed for the security purpose only.	a one-way function and store the hash only.
Raw SQLi / XSS payloads in full	Storing malicious payloads verbatim may create stored XSS or log injection vulnerabilities in log viewing tools.	OWASP Logging Cheat Sheet: sanitise or truncate payloads before storage. Log enough to characterise the attack, not the weapon.	event: INJECTION_ATTEMPT, payload_type: sql, endpoint: /api/search, first_20_chars_sanitised, source_ip, user_id.

Security Event Taxonomy — What to Log for Each OWASP Category Covered in This Course

Mod	OWASP	Event Type	Required Fields	Alert Condition
M5	A07 AuthN	LOGIN_FAILURE	user_id, source_ip, timestamp, success=false	5+ events / same IP / 60s → HIGH
M5	A07 AuthN	LOGIN_SUCCESS_AFTER_FAILURES	user_id, source_ip, prior_failure_count	1 event after 5+ failures → HIGH (credential stuffing success)
M5	A01 BAC	AUTHORISATION_FAILURE	user_id, user_role, resource, required_role, endpoint	3+ events / same user_id / 5min → HIGH
M5	A01 BAC	IDOR_ATTEMPT	user_id, requested_resource_id, owner_id, endpoint	1 occurrence → HIGH (deliberate probing)
M6	A05 Injection	INJECTION_ATTEMPT	event, payload_type, endpoint, user_id, source_ip	1 occurrence → CRITICAL
M7	A03 Supply Chain	DEPENDENCY_CVE_DETECTED	package_name, version, cve_id, cvss_score	Any CVSS ≥ 7.0 → HIGH; ≥ 9.0 → CRITICAL
M9	A04 Crypto	TLS_DOWNGRADE_ATTEMPT	client_hello_version, cipher_offered, endpoint, source_ip	1 occurrence → HIGH
M9	A08 Integrity	TOKEN_VALIDATION_FAILURE	reason (alg_none/sig_mismatch/role_escalation), token_sub, source_ip	3+ events / same IP / 10min → HIGH
M9	A08 Integrity	INTEGRITY_VIOLATION	endpoint, field_tampered, user_id, submitted_value_hash	1 occurrence → HIGH (basket/price tampering)
M10	A06 Insecure Design	PRIVILEGE_ESCALATION_ATTEMPT	user_id, user_role, required_role, endpoint_accessed	1 occurrence → CRITICAL
M10	A10 Exceptional	UNHANDLED_EXCEPTION	correlation_id, endpoint, exception_class (server-side log only)	50+ / 60s global → MEDIUM (spike may indicate attack)
M11	A09 Logging	LOG_TAMPERING_DETECTED	log_file, expected_hash, actual_hash, timestamp	1 occurrence → CRITICAL (attacker removing evidence)

Before & After: Unstructured vs Structured Security Logging in Flask

BEFORE — What Flask logs by default (vulnerable_shop.py)	AFTER — Structured security logging (vulnerable_shop_fixed.py)
<pre># Flask's default access log: 127.0.0.1 - - [20/Mar/2026 10:23:41] "POST /login HTTP/1.1" 302 - 127.0.0.1 - - [20/Mar/2026 10:23:41] "POST /login HTTP/1.1" 302 -</pre> SOC analyst sees: 2 POST requests. Both 302. Cannot tell: - Who was targeted - What payload was used - Whether auth succeeded or failed - Whether this was an automated attack	<pre>import logging, json, uuid from datetime import datetime def log_event(event, user_id, ip, success, detail=''): security_log.warning(json.dumps({ 'timestamp': datetime.utcnow().isoformat(), 'event': event, 'user_id': user_id, # NOT username 'source_ip': ip, 'success': success,</pre>

- Where the attack originated (IP only, no context)

```
'detail': detail,
'correlation_id': g.correlation_id
)))
```

SOC analyst sees structured JSON. SIEM can:

- Alert: 5+ LOGIN_FAILURE from same IP in 60s
- Correlate: SUCCESS after prior FAILURES
- Attribute: user_id immutable across renames
- Reconstruct: full timeline with milliseconds

SIEM Alert Design Principles

Principle 1: Alert, don't just collect

A log that produces no alerts is an A09 failure by the OWASP 2025 definition. Every event type in the taxonomy must map to at least one SIEM rule or alert threshold.

Principle 2: Threshold = acceptable risk

A threshold is a statement about acceptable risk. '5 login failures before alert' means 4 failures are acceptable noise. If your threat model says credential stuffing is a primary concern, lower the threshold.

Principle 3: Group by the attacker's unit of control

Group LOGIN_FAILURE by source_ip (per-IP brute force) AND by username (distributed attack). Grouping by only one misses distributed attacks from multiple IPs targeting one account.

Principle 4: False positive cost < missed attack cost

Tune thresholds so that a false positive causes minor friction (a security ticket to investigate). A missed attack causes a breach, regulatory fine, and reputational damage. Err toward alerting.

Principle 5: Alert on absence as well as presence

'No LOGIN_FAILURE events in 24 hours' from a high-traffic system is suspicious — it may mean logging has been disabled (MITRE T1562.002). Alert on log silence, not just log events.

UK GDPR / DPA 2018 Log Retention Requirements

Log retention periods (minimum guidance)

Log type	Minimum retention
Security events (login, auth, IDOR)	12 months (ICO guidance)
Web application access logs	6–12 months
Payment / transaction logs	5 years (PCI-DSS)
Admin / privileged user actions	12 months minimum
Failed authentication attempts	3 months (NCSC guidance)

UK GDPR Article 33: 72-hour breach notification

You cannot file a breach notification to the ICO without evidence of what happened, when, and what data was affected. Structured logs with timestamps, user_ids, and correlation_ids are the evidence base for any Article 33 report.

UK GDPR Article 5(1)(e): Storage limitation

Do not retain logs beyond what is necessary for the stated security purpose. Logs containing personal data (IP addresses are personal data under UK GDPR) must be subject to a retention schedule with documented justification.

Data minimisation applies to logs

IP addresses, usernames, and device identifiers are personal data. Log the minimum necessary. Use user_id instead of email. Aggregate or anonymise after the retention window expires.

A09 Through the Course — What Should Have Been Logged for Each Attack

Module	Attack (you performed this)	Event That Should Have Been Logged	Alert It Would Have Triggered	OWASP Category
M5	SQLi login bypass — admin'--	LOGIN_FAILURE: username='admin'--', source_ip, success=false	5+ LOGIN_FAILURE / 60s from same IP → HIGH	A07 AuthN Failure
M5	IDOR — user_id in URL parameter	AUTHORISATION_FAILURE: requesting user_id ≠ resource owner_id	3+ events from same user → HIGH	A01 Broken Access Control
M6	XSS payload in Juice Shop search	INJECTION_ATTEMPT: payload_type=xss, endpoint=/rest/products/search	1 occurrence → CRITICAL	A05 Injection
M6	SQLi — UNION data extraction (DVWA)	INJECTION_ATTEMPT: payload_type=sqli_union, endpoint=/vulnerabilities/sqli/	1 occurrence → CRITICAL	A05 Injection

M7	BeEF browser hook delivery (Day 1 Module 3)	BROWSER_HOOK_DELIVERY: hook.js served, victim_ip, hook_registration	1 occurrence → CRITICAL	A05/A06
M9	JWT alg:none / weak secret forged	TOKEN_VALIDATION_FAILURE: reason=alg_none, token_sub, source_ip	3+ / same IP / 10min → HIGH	A08 Integrity
M9	Basket price tampered via ZAP	INTEGRITY_VIOLATION: endpoint=/api/BasketItems, field=price, user_id	1 occurrence → HIGH	A08 Integrity
M10	Admin panel accessed by non-admin	PRIVILEGE_ESCALATION_ATTEMPT: user_id, role=customer, resource=/administration	1 occurrence → CRITICAL	A06 Insecure Design
M10	Stack trace returned in HTTP response	ERROR_DISCLOSURE: endpoint, status=500, correlation_id (client-facing only)	50+ 500s / 60s → MEDIUM	A10 Exceptional Conditions
M11	Log file deleted or modified by attacker	LOG_TAMPERING_DETECTED: expected_hash ≠ actual_hash, log_file	1 occurrence → CRITICAL	A09 Logging (meta-alert)

A09 Failures That Made Breaches Worse**Equifax (2017)**

Attackers dwelled inside Equifax's network for 76 days before detection. SSL inspection had been disabled on a key monitoring device for 19 months — rendering all security monitoring blind to encrypted traffic. 147 million records exfiltrated without a single alert firing.

Target (2013)

Security monitoring tools — including a \$1.6M FireEye deployment — did alert on the initial malware installation. The alerts were ignored by the security team. This is the complementary A09 failure: logging without alerting, or alerting without response processes.

British Airways (2018)

Payment skimming script ran for 15 days before detection. The absence of Content Security Policy (Module 7 hardening checklist) meant the malicious script ran silently — but even with CSP, the script's data exfiltration requests to a third-party domain should have generated anomalous egress log entries that never produced an alert.

A09 Successes — Logging That Contained Breaches**Capital One (2019) — Detection via logging**

The Capital One breach (100 million records) was detected because the attacker's data exfiltration commands were logged in AWS CloudTrail. A security researcher found the attacker boasting on GitHub, cross-referenced with CloudTrail events, and reported it. The logs existed and were actionable — the gap was in the alerting pipeline, not the collection.

CISA's Known Exploited Vulnerabilities Catalogue

The KEV catalogue (cisa.gov/known-exploited-vulnerabilities-catalog) is built partly from defender telemetry: when enough organisations' security logs show active exploitation of a CVE, CISA flags it as 'known exploited'. Your security log events contribute to the collective defence picture — they are not just for your own SOC.

UK NCSC Logging Made Easy (LME)

NCSC's free Logging Made Easy toolset (github.com/cisagov/LME) provides a structured logging pipeline for organisations without enterprise SIEM budgets. It demonstrates that structured logging with alerting is achievable at low cost — the barrier is design intent, not tool expense.

Keep this card after the course. For every new feature: add the log event types to your design before writing code (Section 3). For every incident: check that the six required fields (Section 1) exist in your logs before filing an ICO Article 33 notification. For every log entry: check it against the 'never log' list (Section 2) before the log reaches persistent storage.